INSTITUTO TECNOLÓGICO
DE BUENOS AIRES

INTERPRETACIÓN SEMÁNTICA DE SOLICITUDES WEB EN CAPA DE APLICACIÓN

ALUMNO/A: Cozzi, Alejandro (Leg. N° 294227)

DIRECTOR/A DE TESIS: Sarraute, Carlos

TALLER: Taller de Tesis 1 – Maestría en Ciencia de Datos

PROFESORES/AS: Salgado, Ariel | Sarraute, Carlos

BUENOS AIRES
SEGUNDO CUATRIMESTRE, 2026

Índice

1. Introducción **2**
1.1. Contexto del proyecto . . . 2
1.2. Justificación del estudio . . . 3
1.3. Alcances del trabajo . . . 4

2. Estado de la cuestión **4**

3. Definición del problema **6**
3.1. Problema general . . . 6
3.2. Preguntas de investigación . . . 7

4. Descripción del set de datos **7**
4.1. Origen y contexto del dataset . . . 7
4.2. Descripción técnica . . . 7

5. Hipótesis **7**

6. Objetivos **8**
6.1. Objetivo General . . . 8
6.2. Objetivos Específicos . . . 8

7. Solución propuesta a desarrollar en el TFI o tesis **8**
7.1. Metodología . . . 9
7.1.1. Ingesta . . . 9
7.1.2. Limpieza y parseo . . . 9
7.1.3. Selección de variables e ingeniería de características . . . 10
7.1.4. Extracción de embeddings . . . 10
7.1.5. Entrenamiento . . . 10
7.1.6. Prueba, pruebas cruzadas y recolección de métricas . . . 10
7.2. Técnicas / Herramientas . . . 10
7.2.1. Infraestructura: . . . 10
7.2.2. Procesamiento y limpieza de datos: . . . 11
7.2.3. Extracción de embeddings: . . . 11
7.2.4. Manejo de datos a gran escala: . . . 11
7.2.5. Entrenamiento y clasificación: . . . 11
7.2.6. Evaluación: . . . 11

8. Cronograma de actividades **12**

9. Limitaciones **12**
9.1. Origen del dataset . . . 12
9.2. Dependencia de las etiquetas . . . 12
9.3. Rendimiento e integración en producción . . . 13

1. Introducción

1.1. Contexto del proyecto

Es habitual ver personajes asociados al ciberdelito en el cine, utilizados para resolver situaciones que demanda la trama como anular la seguridad de un banco, obtener información secreta, manipular semáforos, etc. Eso se debe en parte a que en las últimas décadas, muchos de los activos más valiosos del planeta pasaron a ser digitales, ocupando el lugar de un banco o una joyería en los referidos a mediados del siglo XX. Pero esa imagen que ha construido el cine, de un personaje aislado y obscuro, escribiendo código de programación a gran velocidad y penetrando sistemas tiene poca relación con la realidad, la cual habitualmente suele ser menos atractiva y mucho más próxima.

Un ejemplo más cercano y real son los ataques de ingeniería social que se reportan a diario, orientados a tomar el control del *Whatsapp* de la víctima, o incluso de su *Home Banking*, ambos parte del mismo problema. Así como fue en la década de 1990 y 2000 el correo del príncipe Nigeriano que contactaba a usuarios aleatorios por mail pidiendo ayuda para sacar fortunas de su país, o los millones de mensajes que llegan a diario con felicitaciones por haber ganado un premio.

Del otro lado, los proveedores de servicios digitales, intentan concientizar a los usuarios alertando sobre estafas, filtrando hacia la carpeta de Spam los correos sospechosos o bloqueando la clave después de varios fallos, por tratarse de un posible ataque de fuerza bruta. La seguridad se asume como responsabilidad compartida y se distribuye en todos los niveles posibles, desde el desarrollo seguro de aplicaciones, filtros en la red perimetral, doble factor de autenticación, etc.

En uno de esos niveles se encuentra el cortafuegos de aplicación o **WAF (Web Application Firewall)**, una tecnología desarrollada en la década de 1990 (vinculada al nacimiento de la World Wide Web en 1993) especializada en analizar el tráfico que solicita llegar a una aplicación web y tomar acciones sobre esas solicitudes, en definitiva bloquearlas o dejarlas llegar.

Los WAF tradicionalmente aplicaron fórmulas de expresiones regulares (de ahora en más regex) basadas en firmas de ataques conocidos sobre los requerimientos del cliente, aunque en los últimos años han sumado técnicas más variadas como listas de reputación de IPs, bloqueos por geolocalización o detección de bots en base al comportamiento. Este trabajo apunta centralmente a la mejora de ese filtro basándose en firmas de ataques conocidos.

Los CVE (Por *Common Vulnerabilities and Exposures*) son esos **ataques conocidos** mencionados, cada uno de ellos tiene un código de registro utilizado para realizar su seguimiento, el software afectado, formas de mitigación y relación con otros CVEs. A su vez, añade una capa de trazabilidad por lo que cada CVE queda ligado a la publicación de los parches y nuevas reglas de WAF cada vez que surge uno nuevo. En el mismo nombre, radica su debilidad: se trata de reglas y parches relacionados con vulnerabilidades conocidas, asumiendo de facto que antes de su publicación eran desconocidas.

1.2. Justificación del estudio

Imaginemos un escenario donde un cibercriminal logra una forma de penetrar un sistema a partir de una vulnerabilidad del mismo (desconocida hasta el momento). En un lapso de tiempo (que podría durar entre un segundo y varios años) el equipo responsable lo detecta y lo reporta. En ciberseguridad, ese momento se llama ***zero-day***, aun cuando la vulnerabilidad pueda haber existido desde tiempo atrás, se trata del día cero para el camino de soluciones posibles a ese problema [1].

El reporte de esa vulnerabilidad nueva, sería resuelto por una comunidad de colaboradores o por equipos de desarrollo, luego sería liberado el parche y posiblemente una regla de WAF asociada a esa vulnerabilidad. Después, los responsables de otros servicios con el mismo software en todo el mundo, aplicarían la actualización y el sistema volvería a ser seguro (respecto a esa vulnerabilidad puntual).

En un mundo ideal, ese proceso completo duraría un par de semanas, en el mundo real de 2025 ese proceso duró una media de 241 días, según el reporte de Cost of Breach que IBM publica cada año[2]. Si bien como demuestra el informe, ese proceso ha mejorado en los últimos años (en parte gracias a los paradigmas de desarrollo *agile* y filosofías de CICD como DevOps y sus derivados) es probable que nunca sea suficiente para cerrar esa ventana temporal de exposición, siguiendo un pipeline de detección-reporte-actualización-parcheo.

Este trabajo busca **explorar posibles soluciones o reducciones de esa ventana, a partir de técnicas y algoritmos de aprendizaje automático**, aplicadas en la capa de WAF para detectar solicitudes maliciosas.

Un ejemplo no imaginario fue el caso de un CVE conocido como «Log4Shell» de 2021 reportado por un empleado de *Ali Baba Cloud* el 24 de noviembre y asumido por *Apache Software Foundation* el 10 de diciembre de ese mismo año. *Akamai*, un productor privado de WAF, publicó parches al día siguiente [3] y el Instituto Nacional de Estándares y Tecnología (de EEUU, NIST por sus siglas en inglés) en [4] el 12 de diciembre del mismo año. Como se señala en [5] la vulnerabilidad existía al menos desde 2016, cuando se publicó el trabajo de [6] y cuya existencia podría remontarse hasta 2013, año en que se publicó el *commit* que dio origen a la vulnerabilidad [7]. Los primeros parches no fueron suficientes, lo que requirió nuevas versiones publicadas sobre el mismo, hasta el 28 de diciembre de 2021 [8].

La vulnerabilidad tuvo notoriedad mundial ya que afectó a plataformas populares como Minecraft, Twitter y Cisco, y su difusión permitió miles de ataques efectivos en los primeros días y cientos de millones de dispositivos afectados [9]. Es difícil establecer una ventana temporal de exposición global para «Log4Shell», pero podríamos decir que como mínimo fue de alrededor de un mes, y como máximo, de 8 años. Según un informe *Zero Days, Thousands of Nights*, publicado por Rand Corporation en 2017 , la esperanza de vida de un zero day ronda los 6.9 años [10].

Las técnicas aplicadas en «Log4Shell» no diferían demasiado de los ataques conocidos previamente. Sobre este supuesto, tiene sentido la propuesta de pensar un sistema de aprendizaje automático que trabaje junto a las reglas de WAF pero de forma más flexible que las mismas, basados en el comportamiento continuo de las solicitudes.

1.3. Alcances del trabajo

Clasificar solicitudes web utilizando técnicas y algoritmos de aprendizaje automático, trabajando junto al WAF, de mínima podría mejorar los ratios de detección e incluso detectar reglas que no se han configurado o no se han actualizado correctamente. De máxima, podría detectar una vulnerabilidad de ***zero-day***, antes de la publicación por los organismos de seguimiento y parcheo. No obstante es necesario tener en consideración las limitaciones intrínsecas a la propia propuesta desde lo práctico y lo conceptual.

En principio, el set de datos utilizado, proviene de un entorno controlado [11], desplegado *ad hoc* para investigación y no de un entorno de producción real. Los logs de tráfico web contienen información sensible, valiosa y confidencial que otorga demasiada información sobre el negocio y el desarrollo, por lo cual es esperable que en general no se publiquen.

Por otro lado, como se explica en el punto 3.1, actualmente se reconocen cerca de 80 tipos de ataques y es poco probable que un dataset contenga a todos los tipos de ataques y en cantidades medianamente balanceadas. No está de más mencionarlo aunque parezca trivial: los tipos de ataques que no estén en el entrenamiento, tampoco estarán en la predicción.

Si el insumo de datos principal es un conjunto de datos etiquetados, el proyecto nace con una dependencia externa, que a su vez plantea otras dificultades: el WAF etiquetando produce falsos positivos, los cuales serían tomados como referencia, contaminando el entrenamiento del modelo. Si en su defecto quisiéramos realizar el etiquetado a partir de análisis forense humano, el tiempo y costo de la producción de datos se dispararía, imposibilitando procesos de reentrenamiento automatizado y aun así, sin garantizar la certeza de las etiquetas, aunque este dataset en particular sí tuvo una revisión forense posterior (ver 4).

En cualquier caso la solución no se propone como un reemplazo al WAF y sus reglas, sino como un complemento adyacente al WAF que pueda ofrecer una solución híbrida para aumentar la seguridad del asset protegido. Quedaría pendiente de analisis la forma técnica en que esa solución podría integrarse de forma eficiente en un WAF para trabajar en un entorno productivo, sin quitarle rendimiento al tráfico.

2. Estado de la cuestión

Mejorar los niveles de detección de ataques en WAF a partir de los datos, es un problema constante y recurrente dado que la cantidad y creatividad de los ataques se sostiene en el tiempo. Las dinámicas elementales desde el punto de vista técnico para quienes no estén familiarizados con el problema de la seguridad y la acción del WAF son trabajadas en [12] donde se realiza una exploración metodológica acerca de la arquitectura necesaria para detectar y bloquear amenazas de tipo SQLI; si bien menciona los aportes que podrían hacer las técnicas de deep learning en esa capa, no incluye ninguna en su propuesta. Sí aporta algunas nociones metodológicas que podrían ayudar en la etapa de experimentación y, sobre todo, al momento de comparar con los filtros heurísticos.

En cambio, [13] realiza una aproximación muy similar a la que pretende plantear este trabajo, aunque sobre presupuestos metodológicos diferentes. Si bien parte de arquitecturas transformers para la comprensión semántica de cada solicitud web, apunta

al fine-tuning a partir de RoBERTa, antes que a la extracción de embeddings crudos para su posterior procesamiento. No buscan generalizar sobre un conjunto de solicitudes maliciosas per se, sino que proponen realizar un entrenamiento de modelos singulares para cada aplicación web.

Es probable que el entrenamiento singular tenga mucho sentido a la hora de detectar anomalías, aunque no queda del todo claro en ese trabajo cómo se realizaría el etiquetado ya que en los experimentos se utilizan datasets ya etiquetados como CSIC 2010 y DRUPAL.

En una segunda etapa, luego del fine-tuning de RoBERTa, utilizan OneClassSVM un clasificador binario para detectar los ataques en los datasets, y lo comparan con los aciertos(Ratio de aciertos o True Positive Rate, de ahora en más TPR) y falsos positivos (en adelante FPR por False Positive Ratio) usando ModSec como WAF.

La potencia de RoBERTa también fue utilizada en [14] donde los autores experimentaron con un ensamble bastante más complejo pero con algunos parámetros similares. Su trabajo también utiliza herramientas transformers, RoBERTa en particular y el dataset de CSIC 2010 para pruebas, además del dataset ATRDF 2023. Su propuesta se inspira en el framework GAN de forma muy original: identifican tokens reservados en el dataset original y los enmascaran con un token de máscara (literalment <MASK>), luego utilizan RoBERTa para generar el reemplazo esperable de esa fracción del código, lo cual entrega un dataset paralelo, distinto del original. A continuación utilizan nuevamente RoBERTa para comparar ambos, y calculan la similaridad del coseno de cada palabra para determinar anomalías. Por último, entrenan un clasificador de Random Forest para predecir y discriminar entre «tráfico normal» y «posible ataque».

Otra característica en común de los dos trabajos mencionados anteriormente es que ambos obtienen como resultado esa clasificación binaria.

En cambio en [15] los autores apuntan a entregar ambos tipos de clasificación, una binaria (que discrimine ataque / legítimo) y una multiclase, clasificando hasta 8 clases en total (incluyendo al tráfico legítimo). Partiendo de la extracción de embeddings de la solicitud http, proceden a añadirle ruido usando el algoritmo Da-Sana. Para construir los embeddings utilizaron Keras con un padding posterior para normalizar los largos (es decir recortando las líneas que exceden el largo determinado y completando con ceros las que no llegan a él) usando los datasets CSIC-2010 y ECML/PKDD.

Un desarrollo más amplio y complejo se encuentra en [16]. En este trabajo se presenta un proceso que acuña su propio nombre: DeepPTSD una sigla que describe básicamente el proceso propuesto, de Deep Learning Payload Traffic Detection Method Transfer Semi-Supervised Detection. Se trata de un ensamble bastante sofisticado que se entrena con datasets clasificados públicos y aspira a detectar líneas maliciosas en un WAF. A grandes rasgos el ensamble sigue un proceso similar a los demás, aunque con variantes en cada paso, por ejemplo los embeddings se extraen con Word2Vec luego se pre-entrena un modelo con esa información usando redes convolucionales. Con los resultados se realiza una aumentación de los datos que sigue dos caminos: «keyword mining» que parte de un dataset de payloads y aplica una ecuación tf-idf para crear una biblioteca de payloads y luego una «payload perturbation» que reemplaza ciertos tokens que detecta similares a los de la biblioteca en la línea a analizar.

Los trabajos mencionados parecen coincidir en un problema central: las reglas de WAF son eficientes para detectar un alto porcentaje de solicitudes maliciosas, pero son incapaces de detectar algunos tipos de ofuscación. Además, por su propia natura-

leza, surgen como reacción a la detección de vulnerabilidades de tipo ***zero-day*** y esa reacción abre una ventana de oportunidad para el ciberdelito.

Es por eso que se busca en todos una solución al problema a partir de los datos, con distintas estrategias que en definitiva resultan en una acción inmediata sobre una solicitud web, en la capa de WAF. Esta solución no implica un reemplazo del sistema de reglas tradicional, sino un complemento que mejore las métricas de detección. En cualquier caso, eso significa básicamente aumentar el TPR y reducir el FPR con distintas estrategias específicas de la ciencia de datos, en un margen de tiempo poco considerable.

Ninguno de los trabajos mencionados probó el rendimiento comparado de distintos modelos transformers, ni su combinación con distintos algoritmos de clasificación. Pero más allá de del aporte cuantitativo que podría aportar el testeo de combinaciones, no se está teniendo en cuenta el gran peso que podría tener un conjunto de variables obtenidas a partir de ingeniería de características, sobre los rendimientos en un modelo predictivo dentro de un WAF.

3. Definición del problema

3.1. Problema general

La seguridad de los activos digitales es un problema a nivel global que dista de poder resolverse de forma taxativa. Hay muchos enfoques al respecto, en este trabajo se toma como referencia el modelo OSI [17] definido por la organización internacional ISO para la seguridad en las comunicaciones computacionales. Más allá del problema de seguridad global, este trabajo se focalizará en **tres problemas** dependientes de este, los cuales se intentarán explicar a continuación.

El modelo OSI define 7 capas de comunicación en redes (física, enlace de datos, red, transporte, sesión, presentación y aplicación). La capa de aplicación (o capa 7) es donde operan los cortafuegos de aplicación, un filtro lógico que media entre una aplicación e internet y se ocupa, entre otras funciones, de definir si una solicitud es legítima o no para proceder a su bloqueo o redireccionamiento hacia el servicio.

Esa definición no es sencilla por varios motivos y la acción que se toma no siempre es la correcta. La OWASP Foundation (por sus siglas en inglés Open Web Application Security Project) reconoce 78 distintos tipos de ataques, aunque la cifra está en constante movimiento. Cada uno de ellos no llega al WAF con una etiqueta de «malicioso» en el encabezado, sino que lo habitual es que se recurra a distintas técnicas de ofuscación para evitar la detección, lo cual constituye el **primer problema**.

Y esa detección, recurre principalmente a expresiones regulares que buscan patrones dentro de la solicitud que podrían ser signo de un ataque de los mencionados.

OWASP provee de forma abierta cerca de 300 reglas para ese fin a través del programa CRS (Owasp Core Rule Set) que se pueden implementar en cualquier WAF. Owasp desarrolló un WAF de código abierto, llamado ModSecurity (de ahora en más Modsec) al cual se le pueden definir esas reglas, con distintos niveles de paranoia. A mayores niveles de paranoia, más cantidad de falsos positivos, a menor, más posibilidades de bypass, lo cual constituye el **segundo problema**.

El **tercer problema** es procedimental: Supongamos que un atacante explota una vulnerabilidad en un sistema (zero-day), los responsables de ese servicio vulnerado detectan la intrusión y lo reportan. Owasp u otro organismo produce una regla para

ese exploit, publican la regla y se reconfigura el WAF con la actualización. Este pipeline produce necesariamente una ventana de oportunidad muy importante como se mencionó en el punto 1.2.

3.2. Preguntas de investigación

¿Es posible encontrar en una solicitud web pistas sobre las intenciones del solicitante? ¿Un modelo clasificador debe entrenarse con el tráfico de un servicio en particular o es posible generalizar? Existe una similitud semántica entre distintos tipos de ataques o cada uno es particular ¿Qué modelo transformers aporta los mejores embeddings para este problema?

4. Descripción del set de datos

4.1. Origen y contexto del dataset

El set de datos fue publicado junto al paper [18] por Harvard Dataverse. Se trata de un conjunto de solicitudes web capturadas mediante un WAF durante 12 días en julio de 2020. El asset protegido era un sitio falso, con software Wordpress que actuó como honeypot con el único fin de obtener tráfico web. El WAF utilizado fue ModSec 2.9.2 con CRS 3.3.0 en modo *Detection Only*, es decir las detecciones no fueron bloqueadas, lo cual contribuyó al desbalance entre passed vs blocked.

Luego de la recolección, las etiquetas fueron revisadas «manualmente» y almacenado en csv.

4.2. Descripción técnica

El dataset contiene 907.814 requests: 525.195 normales y 382.619 anómalas. Cada registro tiene 24 columnas propias del WAF (como puertos, url, timestamp, etc) y un conjunto de 13 etiquetas de detección. La primera etiqueta (000 - Normal) indica si la request es una solicitud legítima; si vale 1, el resto de las etiquetas debe valer 0. Si vale 0, al menos una de las 12 etiquetas restantes vale 1. Como una request puede combinar varios ataques, la suma de clasificaciones de la Tabla 1 (918.176) supera el número de requests. La mayoría de las requests tiene una única clasificación 898.576, 8.132 tienen dos, 1.088 tienen tres y 18 tienen cuatro.

Está fuertemente desbalanceado (SQL Injection y en menor medida *Fake the Source of Data* concentran la mayoría de los ataques, mientras que, por ejemplo, *HTTP Request Smuggling* suma solo 1059 requests).

5. Hipótesis

A partir de un conjunto de líneas de log de WAF con tráfico web, etiquetados con una clasificación de ciberseguridad (normal o malicioso, especificando el tipo de ataque) es posible generar nuevas etiquetas para líneas desconocidas, sin necesidad del filtro heurístico del WAF sino con un algoritmo que determine la naturaleza de la solicitud, realizando un trabajo igual o superior al que realiza un WAF.

Tabla 1: Distribución de requests por clasificación CAPEC en SR-BH 2020.

CAPEC	Descripción	Requests	% del total
000	Normal	525 195	57.85
272	Protocol Manipulation	9 153	1.00
242	Code Injection	15 827	1.74
88	OS Command Injection	7 482	0.82
126	Path Traversal	20 992	2.31
66	SQL Injection	250 311	27.57
16	Dictionary-based Password Attack	1 847	0.20
310	Scanning for Vulnerable Software	2 718	0.30
153	Input Data Manipulation	2 272	0.25
274	HTTP Verb Tampering	5 437	0.60
194	Fake the Source of Data	56 145	6.18
34	HTTP Response Splitting	19 738	2.17
33	HTTP Request Smuggling	1 059	0.12

6. Objetivos

6.1. Objetivo General

Clasificar correctamente un conjunto de líneas de log asociadas a tráfico web normal o malicioso, con un ratio igual o superior al que realiza actualmente un WAF.

6.2. Objetivos Específicos

1. ***Interpretación Semántica:*** *Extraer de cada línea de log, las características semánticas particulares que nos aporten información sobre la intencionalidad de la solicitud.*

2. ***Feature Engineering:*** *Identificar las características de la línea que más peso tienen dentro de la definición de la etiqueta.*

3. ***Entrenamiento:*** *Entrenar un modelo clasificador que identifique el o los tipos concretos de ataques en la solicitud.*

4. ***DevOps:*** *Generar un pipeline eficiente que permita procesar solicitudes en menos de 3 segundos.*

7. Solución propuesta a desarrollar en el TFI o tesis

Propongo desarrollar un modelo de aprendizaje automático supervisado que logre interpretar semánticamente las solicitudes web que llegan a un WAF y, en base a esa interpretación, clasificarlas entre los distintos tipos de ataques posibles o solicitud legítima.

Para ello, partiendo de un set de datos previamente clasificado, extraer embeddings de ciertos campos a partir de modelos transformers, extraer características con distin-

tas técnicas de ingeniería y con esa información, entrenar un modelo con un algoritmo clasificador, que pueda hacer esa clasificación sobre datos sin clasificar.

La falta de especificidad del modelo transformers y el algoritmo clasificador se debe a que probaré con distintas combinaciones de ensamble para evaluar los rendimientos de cada combinación.

7.1. Metodología

Se espera lograr un pipeline de datos que permita la experimentación y prueba de distintos modelos y librerías. Para el entorno global se utilizará Kubernetes como infraestructura de soporte, que provea contenedores necesarios para las tareas basados en la filosofía DevOps.

7.1.1. Ingesta

El software de soporte inicial sería una base de datos Postgres (dentro de un contenedor) que podría usar psql para ingestar u otro contenedor con Python y SQLAlchemy para la interacción.

Por la misma naturaleza de las líneas de log (muchas con caracteres especiales y binarios) es necesario insertar línea por línea con una codificación amplia como «latin-1» con un control flexible de errores. Ello no implica descartar ninguna línea (ya que justamente un outlier en este caso podría ser la clave de un ataque) sino por el contrario, garantizando que todas las líneas lleguen a la tabla.

El producto de esta primer etapa debería ser una tabla Postgres que contenga un id (construido a partir de un hash md5 de cada línea), la línea en cuestión como string y su/s label/s como string o vector de strings.

7.1.2. Limpieza y parseo

Esta etapa es compleja por varios motivos y las decisiones que se tomen en ésta pueden cambiar de raíz los resultados finales. En principio no se puede realizar una normalización como se haría con otros sets de datos, ya que eliminar caracteres especiales o aplanar el case (llevar todo a mayúsculas o a minúsculas), nos haría perder información elemental para nuestro objetivo.

Por otro lado, la presencia, dentro del propio contenido de los datos, de símbolos que habitualmente se emplean como separadores de campos incrementa la complejidad del proceso de parseo. Caracteres como la coma (`,`), el punto y coma (`;`), el numeral (`#`) o incluso caracteres de control como el salto de línea (`\n`), el retorno de carro (`\r`) y la tabulación (`\t`) son utilizados con frecuencia por los atacantes para alterar el comportamiento esperado de los mecanismos de procesamiento de datos. Incluso una solicitud legítima puede contener comas (`,`) y eso rompería la estructura de un CSV.

En consecuencia, es necesario analizar individualmente cada conjunto de datos para identificar con precisión la posición de cada variable y asignarla correctamente a los campos de la estructura tabular que serán utilizados en las etapas posteriores del procesamiento.

7.1.3. Selección de variables e ingeniería de características

Se debería realizar un concatenado del método más el cuerpo de la solicitud (body) que incluiría la uri, el payload y el user-agent. Estos elementos están en discusión y la definición requiere un análisis más profundo sobre el dataset en particular. Para la ingeniería de características se podrían hacer varios cálculos sobre la línea en sí, incluyendo: entropía de Shannon, puerto destino, cantidad de caracteres especiales, cantidad de palabras clave, ratio de caracteres especiales sobre el total, largo de la línea, etc.

7.1.4. Extracción de embeddings

Sobre las variables seleccionadas y concatenadas, debería realizarse la extracción de embeddings, a partir de distintas librerías de transformers para probar cuál aporta mejores resultados. En este punto es necesario tomar otra decisión metodológica, relacionada al largo de la línea a tomar: si truncar los resultados sobre el largo de la mayoría y perder parte de los datos (usando un percentil de largo de 95 por ejemplo) o utilizar el máximo perjudicando la velocidad y el consumo de recursos. Entre las librerías que se podrían considerar se encuentran: SecBERT y SecRoBERTa [19], DeBERTa [20], RoBERTa [21], SecureBERT [22], CANINE [23] y DistilRoBERTa [24], aunque la idea no es probar todas. En este punto no tendría sentido mantener los datos en el motor SQL; debería exportarse a un archivo que puedan consumir los algoritmos de entrenamiento como podría ser parquet o archivos de matrices.

7.1.5. Entrenamiento

Con los datos exportados, probar el entrenamiento con distintos algoritmos de clasificación: variantes de *gradient boosting* —LightGBM [25], XGBoost [26] y CatBoost [27]—, Support Vector Machine [28] y PyTorch [29], variando hiperparámetros, porcentajes de entrenamiento y pruebas sobre el dataset.

7.1.6. Prueba, pruebas cruzadas y recolección de métricas

El modelo entrenado, además de probarse con los datos que se apartaron para pruebas del mismo dataset, podrían testearse de forma cruzada con datos de otro dataset para ver la flexibilidad del modelo.

7.2. Técnicas / Herramientas

A continuación se detallan varias de las tecnologías, librerías y algoritmos concretos que se emplearán para ejecutar cada una de las etapas descritas en el punto 7.1. Es probable que en la etapa de experimentación algunas se reemplacen o se añadan otras.

7.2.1. Infraestructura:

Kubernetes como orquestador de contenedores para las distintas etapas del pipeline, y PostgreSQL como motor de base de datos para la ingesta inicial de los logs.

Para orquestar y ejecutar las pruebas cross entre transformers y clasificadores, Apache Airflow conectado a Kubernetes con KPO (Kubernetes Pod Operator) para que cada tarea construya su propio contenedor aislado y efímero.

7.2.2. Procesamiento y limpieza de datos:

Python como lenguaje principal, junto con las librerías pandas y NumPy para la manipulación tabular, el tratamiento de valores nulos y la concatenación de campos.

7.2.3. Extracción de embeddings:

HuggingFace Transformers (`AutoTokenizer`, `AutoModel`) sobre modelos preentrenados de dominio como SecBERT [19] entre otros, con PyTorch [29] como backend de inferencia (con soporte GPU/CPU). La tokenización se realiza con truncamiento y padding a un largo fijo (aún no determinado).

7.2.4. Manejo de datos a gran escala:

Como el entorno de desarrollo está pensado para una laptop personal (con GPU incorporada) es necesario realizar checkpointing de los embeddings por lote en el disco (formato `.npy`) para tolerar mejor los fallos y reanudar procesos que mata el Sistema Operativo. La escritura en formato Parquet (vía PyArrow) para evitar la acumulación de metadata en memoria y si es necesario, en forma de streaming o chunks pequeños.

7.2.5. Entrenamiento y clasificación:

scikit-learn para la partición de datos (`train-test-split`), la binarización de etiquetas multi-clase y el cálculo de métricas; LightGBM como algoritmo de clasificación, además de los otros mencionados.

7.2.6. Evaluación:

Métricas de precisión, recall, f1-score y soporte por clase, junto con promedios micro, macro, ponderado y por muestra, estos últimos particularmente relevantes dado el fuerte desbalance entre clases del dataset.

8. Cronograma de actividades

Semana	Fechas	Tareas	Entregable
7–13	Desde 12/10/2026 hasta 27/11/2026	- Armado de la infraestructura - Ingesta y parseo inicial para experimentar	Infraestructura y parser de ingesta
14–22	Desde 30/11/2026 hasta 29/01/2027	- MVP: prueba de un pipeline completo desde la ingesta hasta la publicación de resultados - Procurar el uso de arquitectura efímera que permita la experimentación	MVP del pipeline completo
23–26	Desde 01/02/2027 hasta 26/02/2027	- Primera quincena: vacaciones - Segunda quincena: resolver la presentación en la conferencia	Presentación en la conferencia
27–30	Desde 01/03/2027 hasta 26/03/2027	- Obtener resultados con todas las combinaciones - Avanzar en la escritura de conclusiones sobre los experimentos	Resultados completos y borrador de conclusiones
31–35	Desde 29/03/2027 hasta 30/04/2027	- Primera quincena: vacaciones - Nuevo estado de la cuestión en base a las últimas publicaciones - Cierre del texto de tesis	Tesis finalizada

9. Limitaciones

9.1. Origen del dataset

Como se mencionó en 4, los datos no son de un entorno productivo real, sino de un entorno controlado desplegado *ad hoc* como honeypot con fines de investigación. Por este motivo, la distribución y la variedad del tráfico pueden diferir de las de una aplicación real. Además, el dataset abarca 12 clasificaciones de ataque frente a las cerca de 80 que se reconocen actualmente, y su distribución está fuertemente desbalanceada. Los tipos de ataque ausentes en el entrenamiento probablemente tampoco estarán presentes en la predicción, y el desempeño sobre las clases minoritarias tendrá una estimación menos confiable.

9.2. Dependencia de las etiquetas

Las etiquetas fueron generadas originalmente por ModSecurity 2.9.2 con CRS 3.3.0 en modo *Detection Only* y revisadas manualmente con posterioridad (ver 4). Esto introduce dos limitaciones. Por un lado, las etiquetas no constituyen una verdad

absoluta: los falsos positivos del WAF que la revisión no corrigió son tomados como referencia y podrían contaminar el entrenamiento, y los ataques que el WAF no detectó y que la revisión no advirtió figuran en principio como tráfico legítimo. Si bien con el doble chequeo el conjunto debería ser mayormente confiable, la estrategia es difícilmente escalable o reproducible en un ciclo de MLOps.

9.3. Rendimiento e integración en producción

La solución no se propone como un reemplazo del WAF y sus reglas, sino como un complemento adyacente que ofrezca una solución híbrida. Queda pendiente de análisis la forma técnica de integrarla de manera eficiente en un WAF que opere en producción sin degradar el rendimiento del tráfico. Además, el objetivo de procesar solicitudes en menos de 3 segundos se evaluará en un entorno de desarrollo basado en una laptop personal, por lo que los tiempos obtenidos no serán comparables directamente a un entorno productivo con volúmenes y exigencias de latencia reales, aunque con la tecnología actual, podría resolverse con escalamiento.

Referencias

[1] National Institute of Standards and Technology. zero-day attack. https://csrc.nist.gov/glossary/term/zero_day_attack, s.f. Computer Security Resource Center (CSRC) Glossary. Definición tomada de CNSSI 4009-2022 y NISTIR 8011 Vol. 3. Accedido: 16-oct-2026.

[2] IBM Security. Cost of a data breach report 2025. Report, IBM, 2025. Disponible bajo registro.

[3] Akamai. CVE-2021-44228 – zero day vulnerability in apache Log4j that allows remote code execution (RCE). Akamai Blog, 11 dic. 2021. https://www.akamai.com/blog/news/cve-2021-44228-zero-day-vulnerability, 2021. Accedido: 18-jul-2026.

[4] National Institute of Standards and Technology (NIST) – National Vulnerability Database. CVE-2021-44228 detail. https://nvd.nist.gov/vuln/detail/CVE-2021-44228, 2021. Accedido: 18-jul-2026.

[5] Raphael Hiesgen, Marcin Nawrocki, Thomas C. Schmidt, and Matthias Wählisch. The race to the vulnerable: Measuring the Log4j shell incident. In *Proceedings of the Network Traffic Measurement and Analysis Conference (TMA '22)*, pages 1–9. IFIP, 2022.

[6] Alvaro Muñoz and Oleksandr Mirosh. A journey from JNDI/LDAP manipulation to remote code execution dream land. Black Hat USA 2016. https://www.blackhat.com/docs/us-16/materials/us-16-Munoz-A-Journey-From-JNDI-LDAP-Manipulation-To-RCE-wp.pdf, 2016. Accedido: 18-jul-2026.

[7] Apache Software Foundation – GitHub Repository. apache/logging-log4j2: MessagePatternConverter.java (historial de commits). https://github.com/apache/logging-log4j2/commits/be881e503e14b267fb8a8f94b6d15eddba7ed8c4/

log4j-core/src/main/java/org/apache/logging/log4j/core/pattern/MessagePatternConverter.java, 2013. Accedido: 18-jul-2026.

[8] National Institute of Standards and Technology (NIST) – National Vulnerability Database. CVE-2021-44832 detail. https://nvd.nist.gov/vuln/detail/CVE-2021-44832, 2021. Accedido: 18-jul-2026.

[9] John Doll, Carson McCarthy, Hannah McDougall, and Suman Bhunia. Unraveling Log4Shell: Analyzing the impact and response to the Log4j vulnerability. *arXiv preprint*, 2025.

[10] Lillian Ablon and Andy Bogart. Zero days, thousands of nights: The life and times of zero-day vulnerabilities and their exploits. Research Report RR-1751, RAND Corporation, Santa Monica, CA, 2017.

[11] Tomás Sureda Riera, Juan Ramón Bermejo Higuera, Javier Bermejo Higuera, Juan Antonio Sicilia Montalvo, and José Javier Martínez Herráiz. SR-BH 2020 multi-label dataset. Harvard Dataverse, version V1.2, 2022.

[12] Awring Falah Hassan. Improving web application security via firewall-based detection and prevention of sql injection attacks. *Journal of Digital Security and Forensics*, 3(1):67–74, 2026.

[13] Nicolás Montes, Gustavo Betarte, Rodrigo Martínez, and Alvaro Pardo. Web application attacks detection using deep learning. In *Iberoamerican Congress on Pattern Recognition*, pages 227–236. Springer, 2021.

[14] Udi Aharon, Revital Marbel, Ran Dubin, Amit Dvir, and Chen Hajaj. Roberta-augmented synthesis for detecting malicious api requests. *arXiv preprint arXiv:2405.11258*, 2024.

[15] Hacer Karacan and Mehmet Sevri. A novel data augmentation technique and deep learning model for web application security. *IEEE Access*, 9:150781–150797, 2021.

[16] Tieming Chen, Yunpeng Chen, Mingqi Lv, Gongxun He, Tiantian Zhu, Ting Wang, and Zhengqiu Weng. A payload based malicious http traffic detection method using transfer semi-supervised learning. *Applied Sciences*, 11(16):7188, 2021.

[17] John D Day and Hubert Zimmermann. The osi reference model. *Proceedings of the IEEE*, 71(12):1334–1340, 1983.

[18] Tomás Sureda Riera, Juan Ramón Bermejo Higuera, Javier Bermejo Higuera, Juan Antonio Sicilia Montalvo, and José Javier Martínez Herráiz. Sr-bh 2020 multi-label dataset. *SR-BH 2020 multi-label dataset*, 2022.

[19] Jackaduma. Secbert: A pre-trained language model for cybersecurity, 2022. Accedido: 2026.

[20] Pengcheng He, Xiaodong Liu, Jianfeng Gao, and Weizhu Chen. Deberta: Decoding-enhanced bert with disentangled attention. In *International Conference on Learning Representations (ICLR)*, 2021.

[21] Yinhan Liu, Myle Ott, Naman Goyal, Jingfei Du, Mandar Joshi, Danqi Chen, Omer Levy, Mike Lewis, Luke Zettlemoyer, and Veselin Stoyanov. Roberta: A robustly optimized bert pretraining approach. *arXiv preprint arXiv:1907.11692*, 2019.

[22] Ehsan Aghaei, Xi Niu, Waseem Shadid, and Ehab Al-Shaer. Securebert: A domain-specific language model for cybersecurity. In *Security and Privacy in Communication Networks (SecureComm 2022)*, volume 462 of *LNICST*, pages 39–56. Springer, 2023.

[23] Jonathan H. Clark, Dan Garrette, Iulia Turc, and John Wieting. Canine: Pre-training an efficient tokenization-free encoder for language representation. *Transactions of the Association for Computational Linguistics*, 10:73–91, 2022.

[24] Victor Sanh, Lysandre Debut, Julien Chaumond, and Thomas Wolf. Distilbert, a distilled version of bert: smaller, faster, cheaper and lighter. *arXiv preprint arXiv:1910.01108*, 2019.

[25] Guolin Ke, Qi Meng, Thomas Finley, Taifeng Wang, Wei Chen, Weidong Ma, Qiwei Ye, and Tie-Yan Liu. Lightgbm: A highly efficient gradient boosting decision tree. In *Advances in Neural Information Processing Systems (NeurIPS)*, volume 30, pages 3146–3154, 2017.

[26] Tianqi Chen and Carlos Guestrin. XGBoost: A scalable tree boosting system. In *Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, pages 785–794, 2016.

[27] Liudmila Prokhorenkova, Gleb Gusev, Aleksandr Vorobev, Anna Veronika Dorogush, and Andrey Gulin. Catboost: Unbiased boosting with categorical features. In *Advances in Neural Information Processing Systems (NeurIPS)*, volume 31, 2018.

[28] Corinna Cortes and Vladimir Vapnik. Support-vector networks. *Machine Learning*, 20(3):273–297, 1995.

[29] Adam Paszke, Sam Gross, Francisco Massa, Adam Lerer, James Bradbury, Gregory Chanan, Trevor Killeen, Zeming Lin, Natalia Gimelshein, Luca Antiga, Alban Desmaison, Andreas Köpf, Edward Yang, Zachary DeVito, Martin Raison, Alykhan Tejani, Sasank Chilamkurthy, Benoit Steiner, Lu Fang, Junjie Bai, and Soumith Chintala. PyTorch: An imperative style, high-performance deep learning library. In *Advances in Neural Information Processing Systems (NeurIPS)*, volume 32, pages 8024–8035, 2019.